

SecurityGroup101 — CSA STAR Level 1: CAIQ v4 Self-Assessment

Cloud Controls Matrix (CCM) v4.0 · Completed by: Maxine Jones, GRC Analyst · July 2026

GRC Portfolio Artifact · github.com/Mkjones10/securitygroup101-enterprise-grc-program

Organization Profile

Organization	SecurityGroup101
Founded	2025
Description	Cloud-native fintech SaaS platform providing financial analytics, digital payment processing, and GRC tooling for mid-market financial institutions.
Cloud Infrastructure	AWS us-east-1 (primary) and us-west-2 (disaster recovery)
Service Type	SaaS — multi-tenant with strict logical data isolation
Regulations	GLBA Safeguards Rule · PCI DSS v4.0 · FFIEC Cybersecurity · SOX IT General Controls
Frameworks	NIST CSF 2.0 · ISO 27001:2022 · COBIT 2019 · NIST SP 800-53 Rev 5
Assessment Date	July 2026
Completed By	Maxine Jones, GRC Analyst — mkj00015@mix.wvu.edu
Repository	github.com/Mkjones10/securitygroup101-enterprise-grc-program
Disclaimer	Portfolio artifact. SecurityGroup101 is a fictional fintech company. Control answers grounded in documented Enterprise GRC Program.

CCM v4.0 Domain Summary

CCM Domain	Yes	No	N/A	Overall Risk Level
AIS — Application & Interface Security	8	0	0	Low
BCR — Business Continuity & Resilience	7	0	1	Low
CCC — Change Control & Configuration Management	6	0	0	Low
CEK — Cryptography, Encryption & Key Management	8	0	0	Low
DCS — Datacenter Security	3	0	3	Low
DSP — Data Security & Privacy Lifecycle Mgmt	8	1	0	Low-Medium

CCM Domain	Yes	No	N/A	Overall Risk Level
GRC — Governance, Risk & Compliance	9	0	0	Low
HRS — Human Resources	7	0	0	Low
IAM — Identity & Access Management	9	0	0	Low
IPY — Interoperability & Portability	4	0	2	Low
IVS — Infrastructure & Virtualization Security	6	0	0	Low
LOG — Logging & Monitoring	7	0	0	Low
SEF — Security Incident Management	8	0	0	Low
STA — Supply Chain Management	5	1	0	Low-Medium
TVM — Threat & Vulnerability Management	7	0	0	Low
UEM — Universal Endpoint Management	4	0	2	Low

AIS

Control ID	CAIQ Question	Response	Implementation Statement	Reference / Evidence
AIS-01	Industry standards applied to software development lifecycle (SDLC) security?	Yes	SDLC security framework aligned to NIST SP 800-53 SA (System and Services Acquisition) controls. Security requirements defined during design phase; peer code reviews conducted prior to release; static analysis security testing (SAST) integrated into CI/CD pipeline.	NIST SP 800-53 Rev 5: SA-3, SA-8, SA-11 · ISO 27001:2022: A.8.25, A.8.26
AIS-02	Automated source code analysis tool used to detect security defects before production?	Yes	SAST tooling integrated into CI/CD pipeline scans all code prior to merge. Critical and high severity findings are flagged and block deployment. Findings tracked in risk register with POA&M-style remediation tracking.	NIST SP 800-53 Rev 5: SA-11 · ISO 27001:2022: A.8.28
AIS-03	Documented security requirements for application programming interfaces (APIs)?	Yes	API security standards require: OAuth 2.0 / API key authentication, TLS 1.2+ for all communications, server-side input validation, and rate limiting controls. All API endpoints included in quarterly vulnerability scan scope.	NIST SP 800-53 Rev 5: SA-8, SC-8 · PCI DSS v4.0: Req 6.2.4 · ISO 27001:2022: A.8.26
AIS-04	Web application vulnerability assessments performed on a regular basis?	Yes	Quarterly web application vulnerability assessments conducted against OWASP Top 10 criteria. Critical findings remediated within 30 days per documented SLA. Results tracked in quantitative risk register with ALE modeling to prioritize remediation investments.	NIST SP 800-53 Rev 5: RA-5, SA-11 · PCI DSS v4.0: Req 6.4.2, 11.3
AIS-05	Data input/output integrity routines implemented for applications and databases?	Yes	Input validation and output encoding enforced at application layer per OWASP guidelines. Database referential integrity constraints enforced. Transaction logging and periodic checksum validation implemented. Controls documented in unified control catalog.	NIST SP 800-53 Rev 5: SI-10, SI-12 · ISO 27001:2022: A.8.25
AIS-06	Security documentation provided to tenants for APIs?	Yes	API security documentation maintained in Security Trust Center and developer portal covering: authentication methods, encryption standards, rate limiting policies, data handling, and error handling. Updated with each major API version.	NIST SP 800-53 Rev 5: SA-9 · ISO 27001:2022: A.5.31
AIS-07	Network intrusion detection / prevention systems (IDS/IPS) deployed?	Yes	Network-level IDS/IPS deployed across all cloud infrastructure segments. Security events correlated through SIEM platform. Alert tuning and incident escalation follow documented IR procedures. SOC monitoring architecture documented in portfolio.	NIST SP 800-53 Rev 5: SI-3, SI-4 · FFIEC Cybersecurity: Domain 3
AIS-08	Anti-malware tools deployed on all relevant infrastructure?	Yes	Endpoint protection (EPP/EDR) deployed on all company-managed endpoints and servers. Definition updates automated. Malware detection events generate alerts and trigger documented IR playbook. Coverage validated quarterly.	NIST SP 800-53 Rev 5: SI-3 · PCI DSS v4.0: Req 5.2

BCR

Control ID	CAIQ Question	Response	Implementation Statement	Reference / Evidence
BCR-01	Business continuity plan (BCP) established and documented?	Yes	Comprehensive Business Continuity Plan documented and tested annually, aligned to NIST SP 800-34. Covers: remote work activation, manual financial controls, alternate site operations, and stakeholder communication procedures. Reviewed following major incidents or material organizational changes.	NIST SP 800-34 Rev 1 · ISO 27001:2022: A.5.29
BCR-02	Disaster recovery plan (DRP) established and documented?	Yes	DRP developed for combined ransomware and physical disaster scenario, aligned to NIST SP 800-34. Covers: Tier 1-3 recovery sequencing, AWS multi-region failover (us-east-1 to us-west-2), backup validation, and communication trees. Reviewed and updated annually.	NIST SP 800-34 Rev 1 · ISO 27001:2022: A.5.30
BCR-03	Recovery time objectives (RTO) and recovery point objectives (RPO) defined?	Yes	RTO/RPO defined per asset tier. Tier 1 — Critical (financial processing): RTO 4 hours, RPO 1 hour. Tier 2 — Core (analytics, portal): RTO 8 hours, RPO 4 hours. Tier 3 — Non-critical: RTO 24 hours, RPO 24 hours. Targets validated during quarterly DR tests.	NIST SP 800-34 Rev 1 · FFIEC Cybersecurity Guidance
BCR-04	Business continuity and disaster recovery plans tested at least annually?	Yes	BCP/DRP testing conducted annually per documented DR Testing Schedule. Test types include tabletop exercises, failover drills, and backup restoration verification. Results documented with open findings tracked in GRC roadmap remediation register.	NIST SP 800-34 Rev 1 · ISO 27001:2022: A.5.29
BCR-05	Tenants provided access to data recovery procedures?	Yes	Customer data recovery procedures documented in service agreements and the Security Trust Center. Customers may request full data export through the platform portal at any time. Recovery procedures include data format specifications and committed timeframes.	NIST SP 800-53 Rev 5: CP-9, CP-10 · ISO 27001:2022: A.5.29
BCR-06	Multi-tenant environments provide data protection redundancy?	Yes	Multi-tenant architecture enforces strict logical data isolation at the database layer. AWS multi-region deployment (active-passive) provides geographic redundancy. Tier 1 customer data replicated cross-region with 1-hour RPO.	NIST SP 800-53 Rev 5: SC-5, CP-9 · PCI DSS v4.0: Req 12.3.4

Control ID	CAIQ Question	Response	Implementation Statement	Reference / Evidence
BCR-07	Security requirements included in business continuity plans?	Yes	Security requirements embedded throughout BCP/DRP including: MFA enforcement during failover, encrypted backup validation, and incident response coordination during recovery. Plans reviewed by security team. Controls map to unified control catalog.	NIST SP 800-34 Rev 1 · ISO 27001:2022: A.5.29
BCR-08	Cyber liability insurance maintained?	N/A	Cyber liability insurance under evaluation as part of 18-month GRC roadmap Phase 3. Current risk treatment strategy relies on documented preventive, detective, and corrective controls. Risk register item open; treatment decision expected Q4 2026.	GRC Repository: grc-roadmap.md (Phase 3 — In Planning)

CEK

Control ID	CAIQ Question	Response	Implementation Statement	Reference / Evidence
CEK-01	Industry-standard encryption algorithms used to protect data at rest?	Yes	All customer data at rest encrypted using AES-256. Implementation: AWS S3 server-side encryption (SSE-KMS) with Customer Managed Keys applied to all storage buckets; EBS database volumes encrypted via AWS KMS. Sensitive financial fields (PAN, SSNs, account numbers) additionally encrypted at application layer for defense in depth.	NIST SP 800-53 Rev 5: SC-28 · FIPS 140-2 · PCI DSS v4.0: Req 3.5
CEK-02	Industry-standard encryption algorithms used to protect data in transit?	Yes	All data in transit encrypted using TLS 1.2 or higher. TLS 1.0 and TLS 1.1 explicitly disabled across all endpoints. HTTP connections automatically redirected to HTTPS. API certificate management through AWS Certificate Manager with automatic renewal. Certificate pinning implemented for mobile clients.	NIST SP 800-53 Rev 5: SC-8 · PCI DSS v4.0: Req 4.2.1
CEK-03	Documented encryption key management policy?	Yes	Encryption key management policy documented in security policy framework. AWS KMS used for key lifecycle management (creation, rotation, retirement). Key access restricted to authorized IAM roles; all key usage events logged in AWS CloudTrail. Policy reviewed annually.	NIST SP 800-53 Rev 5: SC-12 · NIST SP 800-57 Part 1 · PCI DSS v4.0: Req 3.7

Control ID	CAIQ Question	Response	Implementation Statement	Reference / Evidence
CEK-04	Encryption keys managed by CSP, tenant, or both?	Yes	Hybrid key management model: AWS-managed KMS keys for standard infrastructure encryption; Customer Managed Keys (CMKs) available for customers requiring direct key control; Bring Your Own Key (BYOK) option available for enterprise customers. Key ownership and rotation documented per data classification tier.	NIST SP 800-53 Rev 5: SC-12 · PCI DSS v4.0: Req 3.7.1
CEK-05	Key rotation policies enforced?	Yes	Automatic annual key rotation enabled for all AWS KMS Customer Managed Keys. Manual rotation procedures documented for keys not supporting automatic rotation. Key rotation events logged in CloudTrail and reviewed during quarterly security governance meetings.	NIST SP 800-53 Rev 5: SC-12 · NIST SP 800-57 Part 1 Rev 5 · PCI DSS v4.0: Req 3.7.4
CEK-06	Customer data encrypted before being transmitted to cloud storage?	Yes	Customer data encrypted in transit (TLS 1.2+) prior to transmission to AWS S3. Application-level field encryption applied to sensitive financial data elements before storage, providing cryptographic defense in depth beyond storage-layer encryption. Both layers independently verifiable.	NIST SP 800-53 Rev 5: SC-8, SC-28 · PCI DSS v4.0: Req 3.5, 4.2
CEK-07	Controls in place to detect unauthorized access to encryption keys?	Yes	AWS CloudTrail captures all KMS API calls including key usage, access attempts, and administrative actions. CloudWatch alarms configured for anomalous key access patterns. Unauthorized key access attempts trigger security incident escalation per documented IR playbook. Monthly key access reviews conducted.	NIST SP 800-53 Rev 5: AU-2, SI-4 · PCI DSS v4.0: Req 10.7
CEK-08	Cryptographic strength reviewed and validated periodically?	Yes	Cryptographic standards reviewed annually against current NIST SP 800-57 guidance and known protocol vulnerabilities (e.g., cipher suite deprecations). Reviews documented in GRC governance meeting minutes. Cryptographic posture review included as recurring activity in 18-month GRC roadmap.	NIST SP 800-57 Part 1 Rev 5 · NIST SP 800-53 Rev 5: SC-13

Control ID	CAIQ Question	Response	Implementation Statement	Reference / Evidence
DSP-01	Data classification policy in place?	Yes	Data classification policy documented in GRC governance model defining four tiers: Public, Internal, Confidential, and Restricted. Financial data (PAN, account numbers), PHI, and PII classified Restricted. Classification tier drives encryption requirements, access controls, retention schedules, and disposal procedures.	NIST SP 800-53 Rev 5: RA-2 · PCI DSS v4.0: Req 3.1 · ISO 27001:2022: A.5.12
DSP-02	Documented data retention and secure disposal policy?	Yes	Data retention and secure disposal policies aligned to GLBA Safeguards Rule and customer contractual requirements. Retention schedules defined per data classification tier. Secure disposal applied to physical media (DoD 5220.22-M wipe or physical destruction) and cloud storage (cryptographic erasure). All disposal events logged for audit.	NIST SP 800-53 Rev 5: MP-6 · GLBA Safeguards Rule · PCI DSS v4.0: Req 3.2
DSP-03	Controls in place to detect and remediate data leakage?	Yes	Data Loss Prevention (DLP) controls deployed at network and endpoint layers. Cloud-native DLP monitors outbound traffic for sensitive data patterns (PAN, SSN formats, classification markings). DLP alerts integrated with SIEM platform and trigger incident response per documented playbook.	NIST SP 800-53 Rev 5: SI-12 · PCI DSS v4.0: Req 3.3 · ISO 27001:2022: A.8.12
DSP-04	Data processed in geographic locations consistent with regulatory requirements?	Yes	All customer data stored and processed exclusively in AWS US regions (us-east-1 primary, us-west-2 DR). Data residency commitments documented in customer agreements. Cross-border data transfers prohibited without explicit customer consent and documented legal basis. Residency controls validated in GLBA gap analysis.	GLBA Safeguards Rule · NIST SP 800-53 Rev 5: SA-9 · ISO 27001:2022: A.5.33
DSP-05	Process in place for responding to data subject access requests (DSARs)?	Yes	DSAR response process documented in privacy operations procedures with 30-day response SLA. Process covers: access, correction, and deletion requests. Requests logged and tracked through completion. Designated privacy contact (privacy@securitygroup101.com) receives and manages requests.	GLBA Safeguards Rule · ISO 27001:2022: A.5.34
DSP-06	Public privacy notice / privacy policy available?	Yes	Public privacy notice maintained on SecurityGroup101 website and Security Trust Center. Covers: data categories collected, processing purposes, third-party sharing, retention periods, and individual rights. Reviewed annually and updated following material changes to data processing activities.	GLBA Safeguards Rule · ISO 27001:2022: A.5.34

Control ID	CAIQ Question	Response	Implementation Statement	Reference / Evidence
DSP-07	Data ownership and stewardship roles defined?	Yes	Data ownership roles defined in GRC governance model. Data owners assigned per classification tier with documented responsibilities for classification decisions, access authorization, and retention management. Roles included in RACI matrix. Annual role review conducted with ownership confirmations.	NIST SP 800-53 Rev 5: RA-2 · ISO 27001:2022: A.5.10
DSP-08	Process for notifying tenants of security incidents affecting their data?	Yes	Breach notification procedures documented in incident response plan and included in all enterprise customer agreements. Notification SLA: 72 hours of suspected breach confirmation. Notifications include: incident classification, data categories affected, timeline, containment actions taken, and recommended customer response actions.	GLBA Safeguards Rule · NIST SP 800-53 Rev 5: IR-6
DSP-09	Customer data sharing with third parties disclosed?	No	Customer data sharing is disclosed in the privacy notice and customer agreements; however, a comprehensive third-party data sharing register documenting all data flows has not yet been completed. This gap is tracked as an open remediation item in GRC Roadmap Phase 2 with target completion Q4 2026. Interim controls prohibit data sharing without documented legal basis.	GLBA Safeguards Rule · GRC Repository: grc-roadmap.md — OPEN GAP — Phase 2 remediation in progress

GRC

Control ID	CAIQ Question	Response	Implementation Statement	Reference / Evidence
GRC-01	Documented information security policy?	Yes	Comprehensive information security policy framework documented in GRC program covering: governance structure, acceptable use, access control, data classification, incident response, vendor management, and cryptographic standards. Policies approved by senior leadership, version-controlled, and reviewed annually.	NIST SP 800-53 Rev 5: PL-1 · ISO 27001:2022: A.5.1
GRC-02	Risk assessments performed on a regular basis?	Yes	Quantitative risk assessments conducted annually using NIST SP 800-30 methodology. Assessments include SLE, ARO, and ALE modeling for 10 critical fintech assets. Risk register maintained with inherent/residual risk scores, treatment decisions, and remediation tracking. Assessment results drive 18-month GRC roadmap priorities.	NIST SP 800-30 Rev 1 · ISO 27001:2022: Clause 6.1

Control ID	CAIQ Question	Response	Implementation Statement	Reference / Evidence
GRC-03	Documented risk treatment and management process?	Yes	Risk treatment decisions (mitigate, transfer, accept, avoid) documented for each risk register item with assigned owners, treatment rationale, and SLA-bound remediation timelines. Risks exceeding defined risk appetite require mandatory treatment plans. Treatment progress reviewed quarterly.	NIST SP 800-30 Rev 1 · NIST SP 800-53 Rev 5: RA-3 · ISO 27001:2022: A.6.1.3
GRC-04	Compliance management program in place?	Yes	Multi-framework compliance management program documented covering: GLBA Safeguards Rule, PCI DSS v4.0, FFIEC Cybersecurity, SOX IT General Controls, ISO 27001:2022, and NIST CSF 2.0. Framework gap analyses completed with identified deficiencies and remediation tracking mapped to unified control catalog.	ISO 27001:2022 Clause 9 · GRC Repository: glba-gap-analysis.md
GRC-05	Third-party audit or assessment performed?	Yes	Third-party security assessments scheduled in GRC Roadmap Phase 3 (Q2 2027). Internal audit activities documented in GRC program. SOC 2 Type II audit engagement targeted for initiation Q1 2027. Penetration testing conducted by independent third party annually.	ISO 27001:2022: A.5.35 · NIST SP 800-53 Rev 5: CA-2
GRC-06	Designated information security officer or equivalent role?	Yes	Information Security Officer (ISO) role defined in GRC governance model with documented responsibilities: security program oversight, risk management reporting, policy maintenance, regulatory liaison, and incident response coordination. ISO reports to CISO. Role included in organizational chart.	ISO 27001:2022: Clause 5.3 · NIST SP 800-53 Rev 5: PM-2
GRC-07	Documented process for reviewing and updating policies?	Yes	Policy lifecycle process defined in governance model: annual scheduled review or triggered review following material changes (regulatory updates, significant incidents, major technology changes). Reviews include stakeholder input, approval by designated policy owners, and version control. Policy change history maintained.	ISO 27001:2022: A.5.1 · NIST SP 800-53 Rev 5: PL-1
GRC-08	Exception / waiver process for security controls documented?	Yes	Security control exception process documented in governance model requiring: written business justification, risk assessment of the exception and residual risk, compensating control identification, time-bound approval by ISO or CISO, and scheduled review date. All exceptions tracked in risk register.	ISO 27001:2022 Clause 6.1 · NIST SP 800-53 Rev 5: PM-1

Control ID	CAIQ Question	Response	Implementation Statement	Reference / Evidence
GRC-09	Regular security awareness training conducted?	Yes	Annual security awareness training mandatory for all employees covering: phishing recognition, social engineering, MFA, password security, data handling, and incident reporting. Role-specific modules for high-risk functions (finance: BEC/wire fraud; IT: cloud security; executives: targeted attack scenarios). Completion tracked and reported to leadership.	NIST SP 800-53 Rev 5: AT-2 · GLBA Safeguards Rule · ISO 27001:2022: A.6.3

IAM

Control ID	CAIQ Question	Response	Implementation Statement	Reference / Evidence
IAM-01	Documented identity and access management (IAM) policy?	Yes	IAM policy documented in GRC governance model, aligned to NIST SP 800-53 AC (Access Control) controls and FFIEC cybersecurity guidance. Policy defines: user account provisioning, de-provisioning, privileged access management, role-based access control, MFA requirements, and periodic access review procedures.	NIST SP 800-53 Rev 5: AC-1 · FFIEC Cybersecurity Guidance · ISO 27001:2022: A.5.15
IAM-02	Multi-factor authentication (MFA) required for production system access?	Yes	MFA enforced for all access to: production systems, administrative consoles, AWS Management Console, VPN, and all privileged accounts. Phishing-resistant MFA (FIDO2 hardware tokens) required for privileged users. Enforced via AWS IAM MFA policies and Conditional Access policies. No MFA exceptions permitted for production access.	NIST SP 800-53 Rev 5: IA-2 · PCI DSS v4.0: Req 8.4.2 · NIST SP 800-63B
IAM-03	Access to systems provided based on least privilege principles?	Yes	Least-privilege access enforced through RBAC. Access rights provisioned based on job function through defined roles — not individual permissions. Current RBAC matrix documents 7 roles and 54 functional modules with field-level security controls. Access rights reviewed and validated against role definitions quarterly.	NIST SP 800-53 Rev 5: AC-2, AC-6 · ISO 27001:2022: A.8.2
IAM-04	Periodic user access reviews performed?	Yes	Access reviews conducted on defined cadence: privileged accounts — quarterly; standard user accounts — semi-annually; service accounts — quarterly. Review results documented, unjustified access revoked within 5 business days. Review procedures aligned to NIST SP 800-53 AC-2 and FFIEC guidance.	NIST SP 800-53 Rev 5: AC-2 · ISO 27001:2022: A.5.18

Control ID	CAIQ Question	Response	Implementation Statement	Reference / Evidence
IAM-05	Formal user provisioning and de-provisioning process?	Yes	Joiner-Mover-Leaver (JML) process documented in governance model. Provisioning: documented manager authorization required before account creation. De-provisioning: all accounts disabled within 24 hours of HR termination notification; full access removal completed within 48 hours. Process validated during quarterly audit activities.	NIST SP 800-53 Rev 5: AC-2 · ISO 27001:2022: A.5.18
IAM-06	Privileged access accounts managed separately from standard user accounts?	Yes	Privileged accounts maintained separately from standard user accounts. Privileged Access Workstations (PAWs) used for all administrative tasks. Just-in-time (JIT) access provisioned for cloud console privileged access with automatic expiration. All privileged account activity logged and monitored for anomalies.	NIST SP 800-53 Rev 5: AC-6, AC-17 · PCI DSS v4.0: Req 7, 8
IAM-07	Single Sign-On (SSO) available for customer access?	Yes	SSO supported for enterprise customers via SAML 2.0 and OAuth 2.0 federation. MFA enforced at Identity Provider (IdP) level when SSO configured. SSO configuration documentation provided to enterprise customers. Implementation documented in Azure AD / Entra ID portfolio project.	NIST SP 800-53 Rev 5: IA-2 · ISO 27001:2022: A.8.5
IAM-08	Service accounts and non-human identities managed with appropriate controls?	Yes	Service accounts inventoried in IAM register with documented owner, purpose, and permissions. Credentials managed through AWS Secrets Manager with automatic rotation. Service accounts granted minimum required permissions only. Service account activity logged and reviewed for anomalous behavior.	NIST SP 800-53 Rev 5: IA-2, IA-4 · PCI DSS v4.0: Req 8.6
IAM-09	Controls to detect and respond to unauthorized access attempts?	Yes	AWS GuardDuty and CloudTrail provide continuous monitoring for unauthorized access. Account lockout enforced after 5 consecutive failed authentication attempts. Failed authentication events above defined thresholds generate SIEM alerts. Unauthorized access events escalated per IR playbook.	NIST SP 800-53 Rev 5: SI-4, AC-7 · PCI DSS v4.0: Req 8.3.4, 10.7

LOG

Control ID	CAIQ Question	Response	Implementation Statement	Reference / Evidence
LOG-01	Logging and monitoring policy documented?	Yes	Logging and monitoring policy documented in GRC program defining: log retention requirements, event categories to capture, monitoring alert thresholds, on-call escalation procedures, and SIEM tuning governance. Policy aligned to NIST SP 800-53 AU (Audit and Accountability) controls and PCI DSS v4.0 Req 10.	NIST SP 800-53 Rev 5: AU-1 · PCI DSS v4.0: Req 10
LOG-02	Logs generated for all critical security events?	Yes	Comprehensive security event logging enabled across all layers: authentication and authorization events, administrative actions, configuration changes, data access events, and network anomalies. AWS CloudTrail captures all API-level activity. CloudWatch aggregates application and infrastructure logs. Log coverage validated quarterly.	NIST SP 800-53 Rev 5: AU-2, AU-12 · PCI DSS v4.0: Req 10.2
LOG-03	Logs protected from unauthorized access and modification?	Yes	CloudTrail logs stored in S3 with S3 Object Lock (WORM configuration) preventing modification or deletion. Log access restricted to dedicated security team roles via IAM. Log integrity validated through CloudTrail log file validation (SHA-256 digest files). Unauthorized log access attempts trigger SIEM alerts.	NIST SP 800-53 Rev 5: AU-9 · PCI DSS v4.0: Req 10.3
LOG-04	SIEM system deployed?	Yes	SIEM platform deployed aggregating: AWS CloudTrail (API activity), VPC Flow Logs (network), CloudWatch (application metrics), GuardDuty (threat detection), and endpoint telemetry. SIEM configuration includes correlation rules, use case coverage mapped to MITRE ATT&CK, and automated alert generation.	NIST SP 800-53 Rev 5: SI-4 · FFIEC Cybersecurity Guidance
LOG-05	Security alerts reviewed and responded to in a timely manner?	Yes	Alert response SLAs defined by severity: Critical — 1 hour; High — 4 hours; Medium — 24 hours; Low — 5 business days. Response procedures and escalation paths documented in IR playbook. Alert SLA compliance reviewed monthly. Unacknowledged alerts auto-escalate.	NIST SP 800-53 Rev 5: IR-6, SI-4 · FFIEC Cybersecurity Guidance
LOG-06	Audit logs retained for defined and documented period?	Yes	Audit log retention: 12 months online (AWS CloudWatch / S3 Standard), 24 months archival (S3 Glacier). Retention periods satisfy PCI DSS v4.0 Req 10.7 (12-month minimum), GLBA audit requirements, and FFIEC examination expectations. Retention enforced via automated S3 lifecycle policies.	NIST SP 800-53 Rev 5: AU-11 · PCI DSS v4.0: Req 10.7 · GLBA Safeguards Rule

Control ID	CAIQ Question	Response	Implementation Statement	Reference / Evidence
LOG-07	Monitoring capabilities tested and validated regularly?	Yes	SIEM detection rules and monitoring capabilities tested quarterly using simulated attack scenarios aligned to MITRE ATT&CK. DR testing schedule includes monitoring validation exercises. Detection gaps identified during testing tracked in risk register with remediation actions.	NIST SP 800-53 Rev 5: CA-7, SI-4 · ISO 27001:2022: A.8.16

SEF

Control ID	CAIQ Question	Response	Implementation Statement	Reference / Evidence
SEF-01	Documented security incident response plan?	Yes	Comprehensive Incident Response Plan documented aligned to NIST SP 800-61 Rev 2, covering: Preparation (playbooks, contact trees, tooling), Detection & Analysis, Containment & Eradication, Recovery, and Post-Incident Review. Specific playbooks for ransomware, credential compromise, data breach, and DDoS scenarios.	NIST SP 800-61 Rev 2 · ISO 27001:2022: A.5.26
SEF-02	Incident response plan tested at least annually?	Yes	IR plan tested annually through tabletop exercises covering documented scenarios. Most recent exercise: Q2 2026 (ransomware and insider threat scenarios). Test results documented with findings; gaps tracked in GRC roadmap. Lessons learned incorporated into plan updates.	NIST SP 800-61 Rev 2 · ISO 27001:2022: A.5.26
SEF-03	Security incident classification levels defined?	Yes	Incident severity classification defined on four-tier scale. Critical: confirmed data breach, ransomware, system compromise — immediate response, 72-hour customer notification. High: unauthorized access, DDoS — 4-hour response. Medium: policy violation, malware detection — 24-hour response. Low: failed access attempts — 5-day response.	NIST SP 800-61 Rev 2 · ISO 27001:2022: A.5.26
SEF-04	Tenants notified of security incidents affecting their data?	Yes	Customer notification procedures documented in IR plan and embedded in enterprise customer agreements. Notification SLA: within 72 hours of confirmed breach determination. Notifications include: incident classification, data categories affected, timeline, containment actions taken, and recommended customer response actions.	NIST SP 800-53 Rev 5: IR-6 · GLBA Safeguards Rule

Control ID	CAIQ Question	Response	Implementation Statement	Reference / Evidence
SEF-05	Root cause analyses performed after security incidents?	Yes	Post-incident reviews including root cause analysis (RCA) conducted for all High and Critical severity incidents within 5 business days of resolution. RCA findings documented and tracked in risk register. Systemic issues identified trigger control updates, policy revisions, or training interventions.	NIST SP 800-61 Rev 2 · ISO 27001:2022: A.5.27
SEF-06	Forensic investigation capability available?	Yes	Forensic investigation capability maintained through: AWS CloudTrail (12-24 month retention), VPC Flow Logs, GuardDuty findings history, and endpoint telemetry. Evidence collection and chain-of-custody procedures documented in IR plan. Log integrity verification supports forensic admissibility.	NIST SP 800-61 Rev 2 · NIST SP 800-86 · ISO 27001:2022: A.5.28
SEF-07	Escalation path documented for security incidents?	Yes	Incident escalation paths documented by severity tier in IR plan. Critical: CISO and executive team within 1 hour. High: Security Manager within 4 hours. Escalation contacts include: in-house legal counsel, external IR retainer firm, and regulatory notification contacts (FBI IC3, CISA, FFIEC).	NIST SP 800-61 Rev 2 · ISO 27001:2022: A.5.26
SEF-08	Relationships maintained with law enforcement and regulatory bodies?	Yes	Documented contact relationships maintained in IR plan for: FBI Internet Crime Complaint Center (IC3), CISA (cyber incident reporting), FFIEC (financial regulatory), and OCC. Contact information validated annually and used in IR tabletop exercises.	NIST SP 800-61 Rev 2 · FFIEC Cybersecurity Guidance

STA

Control ID	CAIQ Question	Response	Implementation Statement	Reference / Evidence
STA-01	Vendor / supplier risk management program documented?	Yes	Third-party vendor risk management (TPRM) program documented in GRC program covering the full vendor lifecycle: evaluation before onboarding, contract security requirements, ongoing monitoring, and safe offboarding. Vendor risk tiering defined by data sensitivity and production system access. GLBA Safeguards Rule vendor management requirements addressed in gap analysis.	NIST SP 800-53 Rev 5: SA-9 · NIST SP 800-161 Rev 1 · GLBA Safeguards Rule

Control ID	CAIQ Question	Response	Implementation Statement	Reference / Evidence
STA-02	Due diligence conducted on third-party suppliers prior to engagement?	Yes	Security due diligence conducted on all vendors with access to customer data or production systems before onboarding. Due diligence process includes: security questionnaire review (CAIQ or equivalent), SOC 2 Type II report review (where available), penetration test summary review, and compliance certification verification. High-risk vendors require annual re-evaluation.	NIST SP 800-161 Rev 1 · GLBA Safeguards Rule · ISO 27001:2022: A.5.21
STA-03	Security requirements included in third-party contracts?	Yes	Security requirements embedded in all vendor contracts including: breach notification SLA (72 hours), data handling and use restrictions, right-to-audit provisions, encryption requirements, incident response cooperation obligations, and data return or certified deletion upon contract termination.	NIST SP 800-53 Rev 5: SA-9 · GLBA Safeguards Rule · PCI DSS v4.0: Req 12.8
STA-04	Ongoing monitoring of third-party compliance with security requirements?	Yes	Ongoing third-party monitoring includes: annual SOC 2 Type II report review, CISA Known Exploited Vulnerabilities (KEV) catalog monitoring for vendor software, and periodic security questionnaire renewal. Monitoring cadence risk-tiered: high-risk vendors — annual; medium-risk — biennial.	NIST SP 800-161 Rev 1 · NIST SP 800-53 Rev 5: SA-9
STA-05	Subcontractors (fourth parties) disclosed to customers?	Yes	Key subprocessors disclosed in customer agreements and Security Trust Center: Amazon Web Services (infrastructure), Stripe (payment processing), Datadog (monitoring), Okta (identity). Material subprocessor changes require 30 days advance written notice to customers. Security assessments conducted on all subprocessors prior to engagement.	ISO 27001:2022: A.5.21 · GLBA Safeguards Rule
STA-06	Supply chain risks included in risk register?	No	Supply chain risks are addressed in GLBA and FFIEC gap analyses and supplier due diligence; however, formal discrete supply chain risk line items have not yet been incorporated into the quantitative risk register. This is an identified gap tracked in GRC Roadmap Phase 2 with target completion Q4 2026. Interim risk register updated pending full supply chain risk register completion.	NIST CSF 2.0: GV.SC · NIST SP 800-161 Rev 1 — OPEN GAP — GRC Roadmap Phase 2

Control ID	CAIQ Question	Response	Implementation Statement	Reference / Evidence
TVM-01	Documented vulnerability management program?	Yes	Vulnerability management program documented covering: automated scan scope and frequency, CVSS v3.1-based severity classification, SLA-defined remediation timelines, exception handling process, and management reporting. Program aligned to NIST SP 800-53 RA-5 and PCI DSS v4.0 Req 11. Findings tracked in risk register.	NIST SP 800-53 Rev 5: RA-5 · PCI DSS v4.0: Req 11
TVM-02	External penetration testing performed at least annually?	Yes	External penetration testing performed annually by qualified independent third-party firm. Scope includes network perimeter, web applications, APIs, and cloud infrastructure. Internal penetration testing conducted semi-annually. All findings remediated per severity SLAs and tracked in risk register. PCI DSS Req 11.4 compliance maintained.	NIST SP 800-53 Rev 5: CA-8 · PCI DSS v4.0: Req 11.4
TVM-03	Vulnerability scan results reviewed and remediated in a timely manner?	Yes	Vulnerability findings reviewed weekly by security team. Remediation SLAs: Critical — 24 hours; High — 7 days; Medium — 30 days; Low — 90 days. SLA compliance monitored with management reporting. SLA exceptions require documented risk acceptance approved by ISO. POA&M-style tracking maintained in risk register.	NIST SP 800-53 Rev 5: RA-5, SI-2 · PCI DSS v4.0: Req 11.3
TVM-04	Threat intelligence program in place?	Yes	Threat intelligence consumed from: CISA Known Exploited Vulnerabilities (KEV) catalog, AWS GuardDuty threat intelligence feeds, and FS-ISAC (Financial Services Information Sharing and Analysis Center) advisories. Intelligence integrated into SIEM correlation rules and vulnerability prioritization. Critical intelligence triggers out-of-cycle emergency patching.	NIST SP 800-53 Rev 5: SI-5 · FFIEC Cybersecurity Guidance
TVM-05	Process for managing zero-day vulnerabilities?	Yes	Zero-day vulnerability response procedures documented in IR plan. Upon identification via vendor advisory, CISA alert, or internal discovery: immediate escalation to security team, compensating controls implemented within 24 hours pending patch availability, and vendor patch tracking initiated. Security team monitors CISA alerts and vendor security bulletins daily.	NIST SP 800-53 Rev 5: SI-2 · CISA KEV Catalog

Control ID	CAIQ Question	Response	Implementation Statement	Reference / Evidence
TVM-06	Vulnerability management activities reported to management?	Yes	Monthly vulnerability management metrics reported to security leadership: open findings by severity, SLA compliance rate, mean time to remediate (MTTR), and risk posture trend. Annual report to board includes risk-adjusted vulnerability exposure analysis. Reporting aligned to NIST CSF DE.CM and GV.OV outcomes.	NIST SP 800-53 Rev 5: RA-5 · NIST CSF 2.0: DE.CM, GV.OV
TVM-07	CVSS or equivalent scoring used to prioritize vulnerabilities?	Yes	CVSS v3.1 base scores used as starting point for vulnerability prioritization. Base scores adjusted by business impact factors: asset criticality tier, data sensitivity classification, and network exposure. Risk-adjusted priority score determines remediation queue position and SLA applicability. Methodology documented in risk register framework.	CVSS v3.1 (FIRST) · NIST SP 800-30 Rev 1

This CAIQ v4 self-assessment is a GRC portfolio artifact created by Maxine Jones, GRC Analyst (mkj00015@mix.wvu.edu). SecurityGroup101 is a fictional fintech SaaS company founded 2025. All control responses are grounded in the documented Enterprise GRC Program at github.com/Mkjones10/securitygroup101-enterprise-grc-program. Framework references: CSA CCM v4.0, NIST CSF 2.0, ISO 27001:2022, NIST SP 800-53 Rev 5, PCI DSS v4.0, GLBA Safeguards Rule, FFIEC Cybersecurity, NIST SP 800-161 Rev 1.